

12주차 피처 거버넌스와 설명 책임

12주차 · 피처 거버넌스

- 7주차의 피처 저장 구조를 여러 부서와 모델이 함께 쓰면 소유자·접근 목적·변경 책임을 정해야 함
 - `practice/chapter12` 에서 카탈로그·접근 정책·감사 로그·품질 규칙을 구현함
 - 접근 기록은 자동화된 결정의 설명과 이의제기에 답할 근거로 이어짐
- 상세 이론은 `lecture/docs/chapter13.md` 와 `lecture/docs/chapter16.md` 에 그대로 유지함

1. 오늘의 질문

- 피처의 정의와 소유자를 기록하지 않으면 무엇이 깨지는가
- 접근을 막는 일과 접근을 기록하는 일은 왜 둘 다 필요한가
- 품질 위반과 드리프트는 왜 다른 판정을 내려야 하는가
- 자동화된 결정에 이의가 제기되면 기관은 어떤 기록으로 설명하는가

2. 카탈로그가 피처의 신원과 소비자를 기록한다

- 피처 카탈로그(feature catalog)는 피처의 정의·소유자·사용 목적을 한곳에 기록함
 - 정의는 어떤 산식으로 값을 계산하는지 밝힘
 - 소유자는 정의와 품질에 책임질 부서를 정함
 - 사용 목적은 요청이 허용 범위 안에 있는지 판정하는 기준임
- 소비자 목록은 어떤 모델과 서비스가 피처를 읽는지 기록함
 - 정의 변경을 누구에게 알려야 하는지 목록에서 확인함
 - 소비자가 남아 있는 피처는 폐기하지 않음
 - 담당자의 기억이 아니라 기록으로 영향 범위를 정함
- 실습 카탈로그에는 피처 2종이 등록됨
 - `complaint_count` 의 소비자는 9주차 훈련·10주차 서빙·13주차 통합 시스템임
 - `day_unmapped_rate` 의 소비자는 `complaint_model_v1` 서비스임
- 카탈로그에 없는 피처는 요청 단계에서 거부함
 - 등록 밖에서 만든 피처가 접근 통제를 우회하지 못하게 함

3. 인가와 사용 이력이 함께 있어야 통제할 수 있다

- 인가(authorization)는 요청 전에 역할과 행위를 판정함
 - 사용 이력은 요청 뒤에 누가·언제·무엇을·왜 요청했는지 기록함
 - 인가만 있으면 누가 조회했는지 설명하지 못함
 - 기록만 있으면 목적 밖 접근을 막지 못한 채 사고 경위만 남음
- 판정 엔진은 세 관문을 순서대로 확인함
 - 역할이 정책에 등록되어 있는지 확인함
 - 피처가 카탈로그에 등록되어 있는지 확인함
 - 역할이 요청한 행위를 할 수 있는지 확인함
 - 세 관문을 모두 통과하지 못하면 기본값으로 거부함

표 12.1 접근 거부 네 건과 통제 지점

역할·피처·행위	거부 사유	통제 원리
analyst · complaint_count · read_log	로그 열람 권한 없음	행위 단위 권한 분리
external_auditor · complaint_count · read_value	감사 역할은 원시 값 조회 불가	목적에 따른 범위 제한
marketing_bot · complaint_count · read_value	미등록 역할	기본 거부
analyst · resident_arrears · read_value	미등록 피처	카탈로그 게이트

- 실습은 접근 요청 12건 중 8건을 허용하고 4건을 거부함
 - 허용과 거부를 모두 로그에 남김
 - 거부된 건수보다 서로 다른 네 통제 지점이 작동했다는 사실이 중요함
 - 요청 목적을 함께 기록해야 사후에 등록된 목적 안의 사용이었는지 확인할 수 있음

4. 품질과 변경을 배포 전에 통제한다

- 품질 게이트는 개별 값이 계약을 위반했는지 검사함
 - 결측·범위 이탈·중복 키는 해석 대상이 아니라 차단 대상임
- 드리프트는 값의 분포가 시간에 따라 이동했는지 알리는 경보임
 - 계절 변화처럼 정상 원인일 수 있으므로 조사 뒤 판정함
 - 품질 위반과 드리프트를 같은 규칙으로 다루면 정상 변화를 막거나 명백한 오류를 통과시킴
- 실습은 3일×3지역의 9행에 세 규칙을 적용함
 - 완전성·정확성·일관성 규칙이 각각 9/9 통과함
 - 매핑 실패율 상한을 6%로 두면 0일, 5%면 1일, 4.5%면 3일이 차단됨
 - 임계값은 관례가 아니라 하루 업무가 건딜 수 있는 오차에서 역산함
- 정의를 덮어쓰면 과거와 현재의 같은 이름이 다른 뜻을 가짐

- 변경은 새 버전으로 발행하고 영향 소비자를 먼저 찾음
- `day_unmapped_rate` 를 v1에서 v2로 바꾸면 2026-07-02 값이 0.0588에서 0.0556으로 바뀜
- 전체 9행 중 3행이 영향을 받고 소비자 하나에 통보함
- 요청자·승인자·사유·영향 소비자·영향 행 수를 변경 이력에 남김

5. 접근 기록이 설명과 이의제기의 근거가 된다

- 공공의 자동화된 결정은 정확도만으로 운영할 수 없음
 - 시민이나 담당 부서가 결정 이유를 요구하면 사용한 데이터·피처·모델·판정 절차를 설명해야 함
 - 개인정보 보호법 제37조의2는 자동화된 결정에 대한 거부와 설명 요구의 근거를 둠
- 설명과 이의제기에는 다섯 통로가 필요함
 - 고지는 어떤 기준과 절차를 쓰는지 미리 밝힘
 - 거부는 중대한 영향을 주는 자동 결정을 거부할 통로를 둠
 - 설명은 어떤 데이터와 기준이 결과에 영향을 주었는지 제시함
 - 인적 개입은 사람이 다시 검토하고 처리하게 함
 - 기록은 요청과 조치를 로그로 남김
- 3절의 접근 로그와 같은 구조로 이의제기 처리 기록을 남김
 - 누가 언제 어떤 결정에 이의를 제기했는지 기록함
 - 어떤 근거를 검토하고 누가 재처리했는지 기록함
 - 사전에 카탈로그와 사용 이력이 없으면 사후 설명의 근거를 재현할 수 없음
- 그룹별 편향·설명 가능한 AI(XAI)·모델 카드의 상세 실습은 `lecture/docs/chapter16.md` 에서 확인함
 - 12주차 본 실습은 피처 접근과 변경 기록을 만드는 데 집중함
 - 기말고사가 참조하는 `ch12_governance_report.json` 을 유지함

6. 실습 12주차 — 피처 거버넌스 설계와 구현

1단계 — 정책 설계

- 실행 전에 다음 항목을 정하고 근거를 적음
 - 외부 감사 역할에 허용할 행위
 - 정책에 없는 역할의 기본 판정
 - 카탈로그에 없는 피처 요청의 판정
 - 매핑 실패율 상한과 하류 업무 근거
 - 이 설계가 깨지는 조건
- 요청 12건 중 거부 건수와 통제 지점 종류를 예측함

2단계 — 실행

```
cd practice/chapter12
python3 -m venv venv && source venv/bin/activate
pip install -r code/requirements.txt
python run_governance.py
```

```
if role not in ACCESS_POLICY:          decision = "DENY"
elif feature not in catalog_names:     decision = "DENY"
elif action not in ACCESS_POLICY[role]: decision = "DENY"
else:                                  decision = "ALLOW"
```

전체 코드는 *practice/chapter12/code/12-1-feature-governance.py* 참고

3단계 — 결과 대조

- ☐ `practice/chapter12/data/output/ch12_governance_report.json` 을 확인함
 - ☐ 카탈로그에 피처 2종과 소비자가 등록되었는지 확인함
 - ☐ 접근 요청 12건 중 허용 8건·거부 4건인지 확인함
 - ☐ 품질 규칙 세 종류가 각각 9/9 통과했는지 확인함
 - ☐ 정의 변경이 2026-07-02의 3행에만 영향을 주었는지 확인함
 - ☐ 감사 점검표 10항목이 모두 통과하고 `CH13_RUN_PASS` 가 출력되는지 확인함

7. 핵심 요약

- ☐ 카탈로그는 피처의 정의·소유자·목적·소비자를 기록함
- ☐ 인가는 접근을 막고 사용 이력은 판정과 목적을 사후에 설명함
- ☐ 품질 위반은 차단하고 드리프트는 원인을 조사하는 경보로 다룸
- ☐ 접근·변경 기록은 자동화된 결정의 설명과 이의제기에 답하는 근거가 됨

8. 과제

- ☐ `practice/chapter12/data/output/ch12_governance_report.json` 과 정책 설계표를 LMS에 제출함
- ☐ 자기 산출물의 `access_control` 을 근거로 다음을 답함
 1. 허용과 거부 건수를 적고 거부된 요청 네 건의 역할·피처·목적·사유를 표로 옮긴다.
 2. 각 거부를 행위 분리·범위 제한·기본 거부·카탈로그 게이트와 짝짓는다.

3. 접근을 기록만 하고 차단하지 않을 때 생기는 사고를 자기 로그의 요청 한 건으로 설명한다.

□ 수업일 포함 7일 이내에 제출함

9. 더 알아보기

□ 피처 거버넌스의 상세 설명은 `lecture/docs/chapter13.md` 에서 확인함

○ 피처 카탈로그와 접근 등급: §13.2-§13.3

○ 품질 계약과 변경 관리: §13.4

○ 카탈로그·계보 도구 비교: 보충 절

□ 공공 AI 윤리·규제의 상세 설명은 `lecture/docs/chapter16.md` 에서 확인함

○ 그룹별 편향과 형평성 지표: §16.1-§16.2

○ 설명 가능한 AI와 모델 카드: §16.3

○ 자동화된 결정과 이의제기: §16.6

○ 전체 실습은 `practice/chapter12/` 에서 선택적으로 실행함